

Helios Robotics - Information Security Policy

1. Purpose

This policy protects the information of Helios Robotics, its customers and its employees. It applies to every employee, contractor and third party who accesses company systems or data, on company or personal devices, in the office or remotely. Violations can lead to disciplinary action.

2. Authentication

2.1 Passwords

Passwords must be at least 14 characters long. Employees must store passwords only in the company-approved password manager, Vaultwise. Routine password rotation is not required unless a compromise is suspected. Reusing a password across systems is prohibited.

2.2 Multi-factor authentication

Multi-factor authentication (MFA) is mandatory for every company system. Administrator accounts must use a hardware security key. Text-message codes are not accepted as a second factor for any new account.

2.3 Screen lock

All devices must lock automatically after 5 minutes of inactivity. Employees must lock their screen whenever they leave their desk.

3. Access control

3.1 Least privilege

Employees receive only the access they need for their role. Requests for additional access are approved by the system owner and logged.

3.2 Access reviews

System owners review who has access to their systems every 90 days and remove access that is no longer needed.

3.3 Joiners, movers and leavers

New employees receive access on their first working day. When an employee changes role, access that is no longer needed is removed within 5 working days. When an employee leaves the company, all access is removed by 18:00 on their last working day.

3.4 Privileged access

Administrator access to production systems is granted just-in-time and expires after 4 hours. Every privileged session is logged and reviewed weekly.

4. Devices

4.1 Company laptops

All laptops must use full-disk encryption (FileVault on macOS, BitLocker on Windows). Operating system updates must be installed within 7 days of release. Employees must not disable antivirus, firewall or device management software.

4.2 Lost or stolen devices

A lost or stolen device must be reported to the security team within 1 hour of discovery by emailing security@helios-robotics.example. The security team locks and wipes the device remotely.

4.3 Personal devices

Personal phones may be used for company email and chat only if they are enrolled in the mobile device management (MDM) programme. Restricted data may never be stored on personal devices.

4.4 Removable media

USB storage devices are disabled by default. Exceptions require approval from the security team and the devices must be encrypted.

5. Networks

A VPN is required whenever an employee is on a public or untrusted network. Employees must not connect company devices to open Wi-Fi networks without the VPN. Guest Wi-Fi in company offices is separated from the corporate network.

6. Phishing and awareness

Suspicious emails should be reported with the Report Phish button in the mail client. Never forward suspicious emails to colleagues. The security team runs phishing simulations every month. All new employees must complete mandatory security training within their first 5 working days, and all employees repeat it once every year.

7. Data classification and handling

7.1 Classes

Company data is classified as Public, Internal, Confidential, or Restricted. If a document is not labelled, it is treated as Internal.

7.2 Handling rules

- Public data can be shared freely.
- Internal data may be shared inside the company.
- Confidential data may be shared only with people who need it, and must be encrypted when sent outside the company.
- Restricted data (customer credentials, robot fleet keys, source code signing keys) may never be stored on personal devices and may be accessed only from company-managed devices.

7.3 Retention

Application and access logs are kept for 12 months. Confidential business records are kept for 7 years. Personal data of applicants who were not hired is deleted after 6 months.

8. Backups

Production databases are backed up daily. Backups are encrypted with AES-256 and are retained for 35 days. Restore tests are performed every quarter, and the results are reported to the security team.

9. Vulnerability management

Vulnerabilities are patched according to their severity. Critical vulnerabilities must be patched within 72 hours. High-severity vulnerabilities must be patched within 14 days. Medium-severity vulnerabilities must be patched within 30 days. If a patch cannot be applied in time, the system owner must document a compensating control and get approval from the security team.

10. Third-party vendors

Vendors that process company or customer data must pass a security review before they are onboarded and must sign a data processing agreement. Vendors are re-reviewed every year.

11. Reporting incidents

Any suspected security incident must be reported immediately to security@helios-robotics.example or in the #security-help channel. Employees who report incidents in good faith are never penalised, even if the report turns out to be a false alarm. Serious incidents follow the Incident Response Runbook.

12. Frequently asked questions

How long should my password be? At least 14 characters, stored in Vaultwise.

I lost my laptop on the train. What should I do? Report it to the security team within 1 hour of discovering the loss.

Can I save Restricted files on my personal tablet? No. Restricted data may never be stored on personal devices.

How quickly must a critical vulnerability be fixed? Within 72 hours.